

TLP:CLEAR

Переполненный ящик и сброс пароля

Как одна кампания меняет предлог, не меняя инструмент. Июль — сентябрь 2026

Кредофишинг | Самоспуф служебных адресов | Кит на репутационной площадке | Ротация предлога

Параметр	Значение
Период событий	5 июля — 17 сентября 2026 (UTC)
Дата анализа	17 сентября 2026
Классификация	TLP:CLEAR
Уровень угрозы	СРЕДНИЙ
Тип угрозы	Сбор учётных данных почты; вредоносного кода в этой линии нет
Получатель	Общий почтовый адрес правозащитной организации, указанный на её сайте
Результат	Подтверждённых вводов учётных данных нет; письма продолжают приходить

1. Коротко

С июля по сентябрь 2026 года на общий почтовый адрес правозащитной организации идёт непрерывная серия писем, которые сообщают, что почтовый ящик переполнен, срок действия пароля истёк или требуется подтвердить учётную запись. Цель у всех одна: увести человека на страницу, похожую на вход в почту, и забрать пароль.

Само по себе это рядовой сюжет. Интересны три вещи, которые видно только на длинном ряду.

- Предлог сменился, инструмент — нет. 17 сентября отправитель, который два месяца слал «ящик переполнен», поставил в тему «сбросьте пароль». Страница, на которую ведёт письмо, при этом осталась той же самой — совпадает вплоть до идентификатора файла в хранилище. То есть перед нами не две кампании, а одна, у которой предлог — расходный материал.
- Рассылка сменилась давлением. В августе одно и то же письмо ушло веером на шесть региональных адресов организации — 24 письма за три дня. В сентябре тот же объём внимания сведён на один адрес: девять из десяти писем адресованы ему.
- Ни одного собственного домена. За весь период кит ни разу не размещался на домене, который можно было бы снять с делегирования. Только объектные хранилища и публичные шлюзы крупных провайдеров.

Практический вывод для защиты один и он неудобный: правило, опознающее эту кампанию по теме письма, уже устарело — тему сменили один раз и сменят снова. Опознавать надо по устройству страницы и по идентификатору файла, а они держатся неделями.

2. Что именно изменилось в числах

Считали по дате отправки письма, а не по дате, когда мы его разобрали, — иначе ряд показывает всплеск там, где была просто задержка обработки. Доля писем с соответствующей темой во всём входящем потоке организации:

Месяц	Тема «переполнен ящик»	Тема «сброс/истечение пароля»
Июль 2026	0,71 на 100 писем	0,31 на 100 писем
Август 2026	0,59 на 100 писем	3,64 на 100 писем
Сентябрь 2026 (17 дней)	2,55 на 100 писем	0,75 на 100 писем

Тема про переполненный ящик выросла за месяц в 4,3 раза. Тема про пароль, наоборот, отгремела в августе и почти исчезла. Если смотреть только на одну из двух тем, картина получается противоположной реальности: одна «падает», другая «растёт», а на деле это один и тот же поток, переодевшийся между месяцами.

На отдельно взятом адресе, который сейчас под давлением, доля таких писем поднялась с 5,5 % в августе до 20,9 % в сентябре. Каждое пятое письмо, приходящее на общий ящик организации, — приманка этого класса.

3. Три способа положить страницу так, чтобы её нечем было снять

В кампании участвуют как минимум три ветки, и все три решают одну задачу — разместить страницу входа там, откуда её трудно убрать и где домен не вызывает подозрений.

Первая ветка держит кит в объектном хранилище Backblaze B2 и ссылается на него через служебный адрес скачивания файла по идентификатору. Идентификатор файла не меняется

неделями: письма от 10, 11 и 17 сентября ведут на один и тот же объект. Это самое устойчивое, что есть в кампании, и лучший признак для отслеживания.

Вторая ветка каждую волну заводит новый одноразовый бакет Cloudflare R2. Меняется имя бакета целиком, а имя файла внутри — нет: устойчивый шаблон из четырёх букв и семи цифр. Полная ротация адреса при неизменном имени файла — сама по себе сигнатура.

Третья ветка выкладывает кит в IPFS и ссылается на него через публичные шлюзы. Содержимое в IPFS адресуется хешем, то есть страница неизменяема и не привязана к серверу: снять её нельзя в принципе, можно только блокировать шлюзы, которых много.

Общее у всех трёх — отсутствие того, на что обычно направлена жалоба. Нет регистратора, у которого можно отозвать домен, и нет хостера, которому можно написать. Есть крупная площадка с хорошей репутацией, у которой такой объект — один из миллиардов.

4. Адрес жертвы в конце ссылки

Почти во всех письмах ссылка заканчивается решёткой и адресом получателя. Технически это фрагмент URL, и у него есть свойство, ради которого его и используют: браузер фрагмент никуда не отправляет. Он остаётся на стороне клиента и достаётся скриптом уже на открытой странице.

Следствий два. Первое: в журналах веб-сервера видно только обращение к странице, без указания, кому именно она была отправлена, — это лишает защитника возможности установить круг адресатов по логам площадки. Второе: страница сразу знает, чей адрес подставить в форму, и выглядит персонально подготовленной, хотя рассылка массовая.

Отдельно встречается вариант, где адрес не в фрагменте, а закодирован в base64 в параметре промежуточной страницы. Это тот же приём, только менее аккуратный.

5. Письма приходят «от самой организации»

Отправитель подделывает служебные адреса того же домена, на который и нападает: административный ящик, ящик уведомлений, ящик почтового сервера, ящик панели управления хостингом. Получатель видит письмо, формально пришедшее от собственной почтовой службы.

Это работает по конкретной причине: политика домена настроена на «поместить в спам», а не «отклонить». При первой настройке разница кажется косметической, на деле она решающая — подделка доставляется, просто в другую папку, и человек её видит. Организациям, у которых политика стоит в промежуточном режиме дольше пары месяцев, стоит считать это не «почти готово», а «не сделано».

Часть писем идёт иначе: подделывается не адрес, а только отображаемое имя, а сам конверт принадлежит постороннему юридическому лицу. Мы проверяли: в разобранных случаях это подстановка имени, а не взлом чужой почты. Заносить такие домены в списки блокировки нельзя — пострадает непричастный.

6. Почему такую серию легко не заметить

Два механизма, оба общие для многих почтовых конвейеров, дают именно на такой кампании слепое пятно.

Первый: групповые адреса. Общие ящики вида «info@» или «office@» часто являются не пользователями, а группами рассылки, и административные интерфейсы почтовых платформ их в перечислении пользователей не возвращают. Проверка «все ли ящики опрошены» при этом честно отвечает «все», потому что сравнивает пользователей с пользователями. Ровно эти адреса и получают основную долю атак, потому что опубликованы на сайте.

Второй: склейка по отпечатку содержимого. Если конвейер считает отпечаток по текстовой части письма, а операторы кладут туда короткую заглушку в несколько байт, отпечаток вырождается в константу. Десятки разных писем схлопываются в одну «уже известную» запись, и нарастающая серия читается как давно разобранный повтор. Проверять стоит просто: если у отпечатка неправдоподобно много писем, посмотрите, какой длины текст под ним.

7. Индикаторы

Индикаторы приведены с испорченными точками. Одна посадка из последней волны намеренно не публикуется: она может быть ещё живой, и её публикация сообщила бы оператору о наблюдении, ничего не дав защите.

Тип	Значение	Примечание
Посадка (IPFS)	bafkreia5iln5dqpy2fejobjp2ojo2rkduchw2tv7xdf jrhhbfvvyzhp2i	CID кита, шлюз inbrowser[.]link, 11.09.2026
Посадка (IPFS)	bafybeid65s7bjp5kigaj7kbw573wqcz3uiyvzxn xeu5on3tjsoe7nmcsn	CID кита, файл cPweb70.html, шлюз dweb[.]link, 11.09.2026
Бакет (R2)	pub- bde527919f074a9d88485c51e0a7c57c.r2[.]dev	Одноразовый бакет, файл sedu8258773.html, 04.09.2026; выжжен
Бакет (R2)	pub- a4ede915516d42efab13d8916cfb5c1d.r2[.]dev	Тот же кит, файл sedu4257302.html, 07.09.2026; выжжен
Объектное хранилище	f005.backblazeb2[.]com/b2api/v1/ b2_download_file_by_id	Хостинг кита второго оператора; fileId переиспользуется неделями
Идентификатор кита	4_zcc7175a2a5aface295f60211_f104d2b4c72 05c55c	Фрагмент fileId, общий для писем 10.09, 11.09 и 17.09
Бакет (IONOS)	905874987verxgdfsdaswffavdsg79ad77aadfgs bghdr5.s3-eu-central-2.ionoscloud[.]com	Промежуточная страница, адрес жертвы в base64 в параметре data
Шаблон имени	sedu / kedu + 7 цифр + .html	Имя файла кита стабильно при полной ротации бакета
Шаблон URL	<посадка>#<адрес получателя>	Адрес жертвы во фрагменте URL, на сервер не уходит

Не блокировать: домены компаний, от имени которых приходили письма. В разобранных случаях это подстановка отображаемого имени, а не компрометация. Также не включена взломанная панель веб-почты стороннего малого предприятия, использованная как промежуточная страница, — её владелец сам пострадавший.

Техники MITRE ATT&CK: T1566.002 (фишинговая ссылка), T1656 (выдача себя за другого), T1583.006 (использование веб-сервисов как инфраструктуры), T1056.003 (перехват ввода через поддельный веб-портал), T1102.002 (двусторонний канал через легитимный веб-сервис).

8. Что мы бы предложили

- Не строить правила вокруг темы письма. В этой кампании тема — расходный материал, а идентификатор файла с китом держится неделями.
- Считать ссылку, оканчивающуюся решёткой и адресом получателя, самостоятельным признаком. У обычной почтовой рассылки такого не бывает.
- Довести политику проверки подлинности домена до режима отклонения. Промежуточный режим означает, что подделка от вашего же имени доставляется адресату.
- Отдельно проверить, попадают ли в мониторинг общие и групповые адреса. Именно они опубликованы на сайте и именно по ним идёт основной поток.
- Не ждать помощи от снятия домена. В этой кампании снимать нечего: домена нет ни у одной из трёх веток.
- Сотрудникам на общих ящиках — исходить из того, что письмо «от администратора вашей почты» приходит в тот же ящик, что и всё остальное, и выглядит настоящим.

9. Чего мы не знаем

Вводил ли кто-нибудь пароль на этих страницах, мы не знаем. Подтверждённых случаев нет, но и доказательства обратного у нас нет: часть потока идёт на общий адрес, за которым нет персонального журнала входов.

Один ли это оператор или несколько работают по одной методичке, мы не устанавливали. Ветки различаются местом размещения кита и способом подделки отправителя, но совпадают по строению страницы и по приёму с адресом во фрагменте. Этого достаточно, чтобы говорить об общем происхождении кита, и недостаточно, чтобы говорить об одном исполнителе.

Сами посадочные страницы мы не открывали. Любое обращение к ним сообщило бы оператору, что за ним смотрят, и могло бы зарегистрировать фиктивную жертву. Поэтому о текущем состоянии страниц и о том, куда именно уходят введённые данные в последних волнах, судим по устройству ранее сохранённых копий кита, а не по наблюдению вживую.

Числа в разделе 2 посчитаны по одной организации. Это достаточная база, чтобы говорить о смене тактики против неё, и недостаточная, чтобы переносить пропорции на кого-то ещё.

TLP:CLEAR — Этот документ может распространяться без ограничений.